

ShieldAI_{vCISO}

The virtual CISO every small business can finally afford.

Derrick Brooks · Founder & CEO · Xandu Limited, LLC

CONFIDENTIAL · SEED FUNDRAISE · 2026

Every business is a target. Almost none can afford protection.

\$200K–\$400K

Cost of a full-time CISO, per year

47%

Small businesses with zero cybersecurity budget

99%

of US businesses are small or mid-sized

Yet insurers, customers, and regulators now require a real security program — *there is no small-business exemption from the threat landscape.*

The pressure just became unavoidable.

1

Cyber-insurance as gatekeeper

63% of SMBs saw premiums rise 200%+ in 2025; insurers now require proof of MFA and incident response before issuing or renewing a policy.

2

Customer-driven requirements

Larger customers push security questionnaires and insurance requirements down to small vendors — no program, no contract.

3

Expanding regulation

HIPAA, CMMC, the FTC Safeguards Rule, and state privacy laws now carry real penalties, reaching deep into the small-business tier.

4

AI made the cost collapse

Expert-level security analysis is now deliverable at \$0.28 per client per month — the segment is finally economically servable.

An honest look at the landscape.

Company	Buyer	Price / yr	Gap vs. ShieldAI vCISO
Cynomi	MSP / MSSP	Not sold to SMB	Sells only through service providers
Vanta	VC-funded tech co.	\$10K–\$80K+	No engineer review; not SMB-priced
Drata	VC-funded tech co.	\$7.5K–\$100K+	Built for cloud-native engineering teams
Secureframe	VC-funded tech co.	\$7.5K–\$80K+	Guided audit prep, not a full CISO program
Scrut Automation	Mid-market SaaS	\$15K–\$40K	Requires in-house GRC expertise

Every well-funded name in the category sells through an MSP channel or to venture-funded tech companies at 4–50x ShieldAI vCISO's price. Full profiles in the companion Competitive Analysis.

A virtual CISO, powered by AI, overseen by engineers.

- A continuous security program — not a one-time PDF that sits in a drawer
- A real, defensible security score, mapped to NIST CSF and CIS Controls v8.1
- Ready-to-use policies, a prioritized roadmap, training, and compliance tracking
- Priced as a subscription — not a consulting engagement

BEFORE

A drawer PDF from a one-time consulting engagement

AFTER

A living program that scores, updates, and reports on its own — reviewed by a real engineer

Assess → Score → Generate → Monitor → Manage

1

Assess

Conversational intake +
structured checklist across
NIST, CIS v8.1, HIPAA, PCI,
SOC 2

2

Score

Deterministic NIST CSF
engine — not AI guesswork

3

Generate

Policies, roadmap, training,
compliance gap analysis,
executive report

4

Monitor

Optional read-only endpoint
agent (Windows / Linux /
macOS) reports live posture

5

Manage

Continuous oversight +
expert engineer review

Live in production — not slideware.

- Conversational assessment

- Deterministic NIST scoring

- 12 compliance frameworks

- Policy generation (Word export)

- Prioritized roadmap

- Awareness training product

- Executive reporting

- 5-tier billing, live

- Read-only monitoring agent

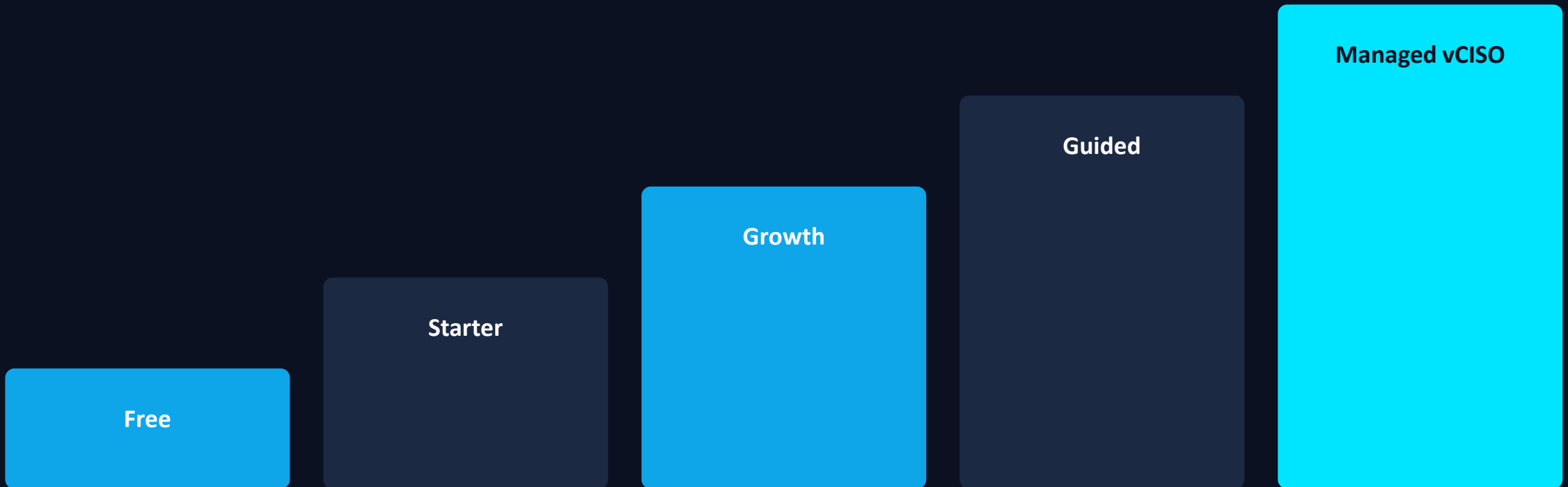
- Analyst console (mockup)

- Mastermind AI co-pilot

- Admin & audit tooling

Client walkthrough: demo@shieldai.com · Platform view: analyst@xandultd.com

Land free. Expand to self-serve.
Grow into managed programs.



Free assessment removes all friction at the door; each stage adds engineer time and recurring value.

Recurring revenue that grows with the relationship.

Free	Starter	Growth	Guided	Managed vCISO
\$0	\$159	\$349	\$699	\$1,950
/month	/month	/month	/month	/month
Assessment & score	Full program, no engineer time	Expanded coverage + training access	+ periodic engineer review	Engineer runs the program end-to-end

+ \$40/mo training delivery add-on for Starter — bundled free at Growth tier and above. Measured AI cost: \$0.28/client/month.

Undercuts traditional human-only vCISO retainers (\$2,500–\$11,600/mo) at every tier.

A large, underserved market being forced to act.



TAM — the vCISO category ShieldAI vCISO directly serves



SAM — regulated / insured / supply-chain SMB segment



SOM — realistic early capture over 3–5 years

5.8M

US employer businesses (36.2M total)

3.4M

unfilled cybersecurity roles globally

Not a wrapper. A defensible system — already built.

1

Deterministic, explainable scoring

A NIST CSF posture score an insurer or auditor can trust — not an opaque AI guess.

2

Human-in-the-loop delivery

A qualified engineer reviews every deliverable — a layer no self-serve compliance platform offers at any price.

3

Compounding data & relationships

Every assessment and managed client makes the system smarter and stickier.

4

Direct-to-SMB reach, at an SMB price

The lane Cynomi, Vanta, Drata, Secureframe, and Scrut Automation have all left structurally open.

Why I'm the one to build this.

Derrick Brooks

Founder & CEO, Xandu Limited, LLC

- ~20 years of cybersecurity experience spanning national-security roles, enterprise CISO work, and hands-on SMB delivery
- Navy Lieutenant Commander; offensive security practitioner
- Zero Trust / Azure implementation experience with real client outcomes
- Credentials: CISSP, CISM, CompTIA Security+
- Dual M.S. in Cybersecurity (National University); MBA in IT Management (SNHU); doctorate in progress (Westcliff University)

AI is nearly free. Engineer time is the real cost.

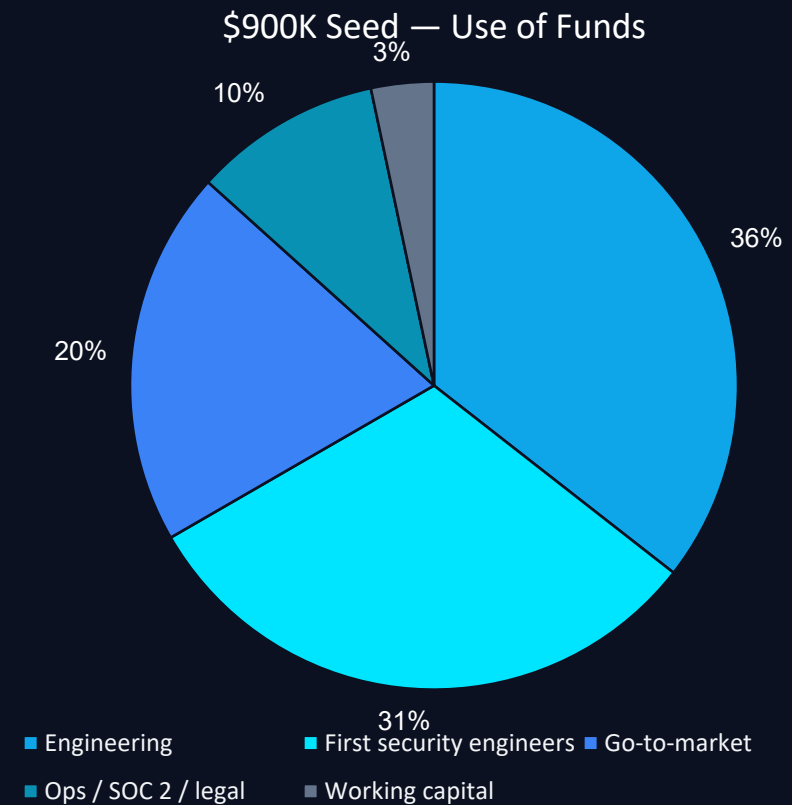
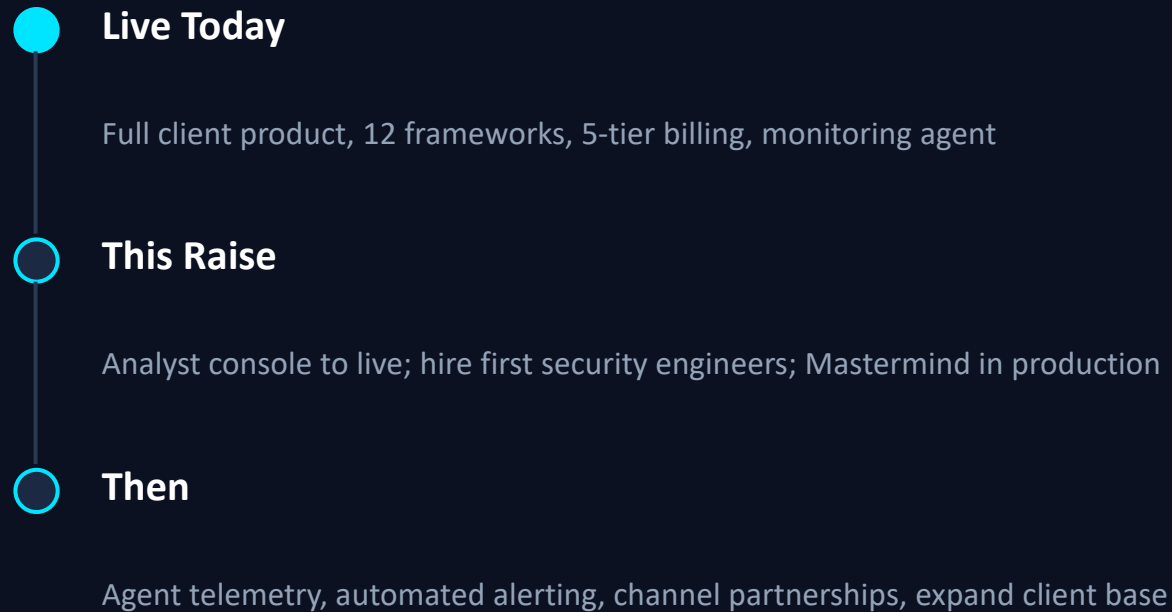
Managed vCISO — Per Engineer

Price	\$1,950 / month
Clients per engineer	~25
Revenue per engineer / yr	~\$585,000
Loaded engineer cost / yr	~\$140,000
AI cost per engineer / yr	~\$84
Contribution margin	~76%

Blended company-wide margin expands as headcount is absorbed by a growing client book:



What this raise unlocks.



\$900,000

Seed round to build the managed-security platform layer
and take ShieldAI vCISO to Series A readiness in 22–24 months.

“A full-time CISO costs a quarter-million dollars a year. ShieldAI vCISO delivers that protection for the price of a subscription — and lets a handful of our engineers protect thousands of businesses.”

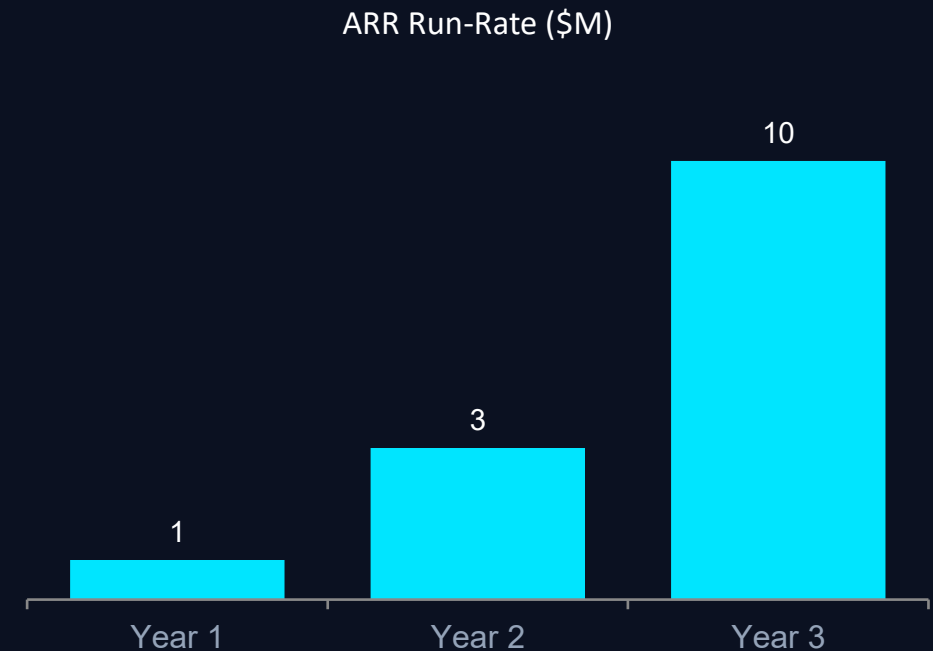


APPENDIX

Backup detail for investor Q&A

A 3-year plan built from a full monthly model.

	Year 1	Year 2	Year 3
Total paying clients	170	610	1,610
Team headcount	5	13	23
ARR (year-end run-rate)	~\$0.9M	~\$3.5M	~\$10.1M
Gross margin	~12%	~58%	~74%
EBITDA margin	~(147)%	~2%	~44%



The \$900K raise is never fully exhausted under this plan — modeled cash bottoms out around \$130K near Month 18, then turns cash-flow positive.

Two boundaries we will not cross.



Human-in-the-loop, always

Every client-facing deliverable is reviewed and approved by a qualified engineer before it ships. AI accelerates the work; it never replaces judgment or accountability.



Analyst isolation

Each engineer's console access is scoped strictly to their assigned clients — no cross-client visibility, enforced at the platform level.



Agents are permanently read-only

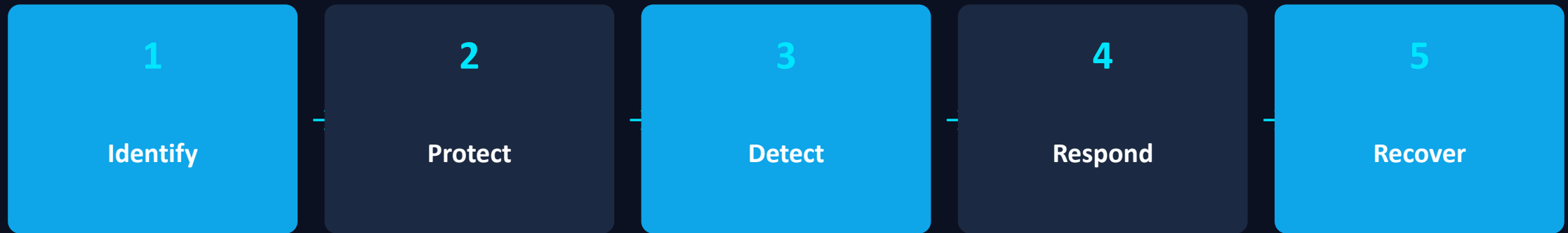
Monitoring agents report posture and telemetry only. There is no inbound command channel — an agent cannot act on a client's environment, ever.



Mastermind is advisory only

The AI co-pilot triages, diagnoses, and surfaces gaps for the engineer. It cannot take action on a client's behalf under any circumstance.

A deterministic engine, not an AI guess.



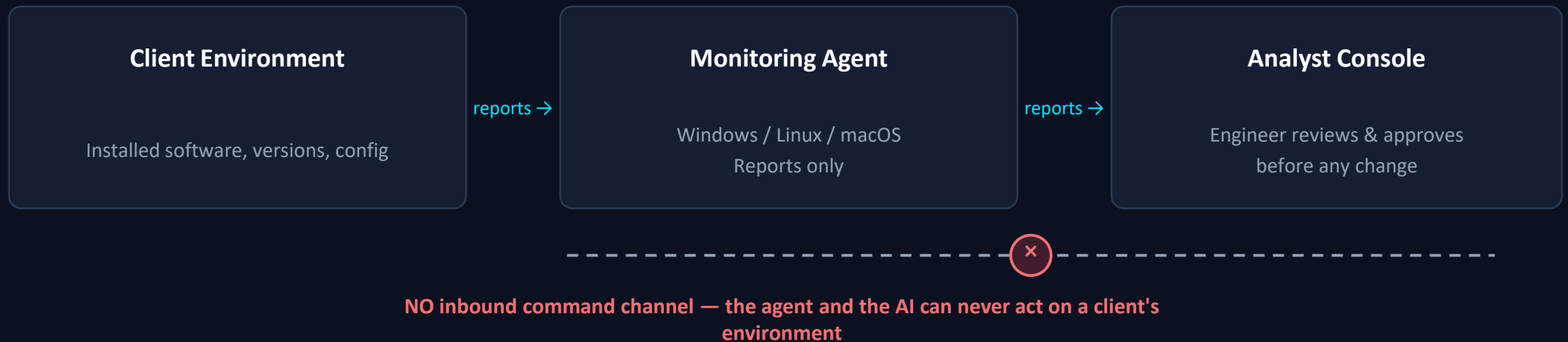
The NIST Cybersecurity Framework's five functions, each weighted and scored from the structured assessment. **The same inputs always produce the same score, and every point traces to a specific control** — which is why insurers and auditors can trust it in a way they'd never trust an opaque AI output. CIS Controls v8.1 mapping is supported alongside NIST CSF.

The full ladder, what's enforced at each tier.

Tier	Price	What's included
Free	\$0	Security assessment and posture score only
Starter	\$159/mo	Full program generation, policy library, endpoint monitoring — no engineer time
Growth	\$349/mo	Expanded policy & endpoint coverage, full training program access, downloads/exports
Guided	\$699/mo	Growth, plus periodic engineer review, compliance tracking, and check-ins
Managed vCISO	\$1,950/mo	A ShieldAI vCISO engineer runs the security program end-to-end

Plus a \$40/month training delivery add-on for Starter — bundled free at Growth tier and above.

The read-only agent boundary.



Only a client admin or a permitted, isolated analyst can make a change — never the agent, never the AI, unilaterally.